

CENTRO UNIVERSITÁRIO LEONARDO DA VINCI — UNIASSELVI

Engenharia de Software — 7º período

Documento de Requisitos

Aplicativo de Detecção de Tentativas de Phishing por Correio Eletrônico

Elaborado a partir da entrevista estruturada (Blocos A–H) e do Termo de Referência v1.0

Equipe executora: Ethan Buttazzi — Projetista, Pesquisador e Implementador

Orientador: Prof. Evaldo A. Oliveira

1. Identificação

Campo	Conteúdo
Documento	Documento de Requisitos v1.0
Projeto de origem	Termo de Referência — Aplicativo de Detecção de Tentativas de Phishing por Correio Eletrônico (v1.0)
Vínculo acadêmico	Trabalho de Conclusão de Curso — Engenharia de Software, 7º período — UNIASSELVI
Fonte das informações	Entrevista estruturada (Roteiro de Entrevista, Blocos A–H) conduzida com a equipe executora
Data de emissão	24/09/2026

2. Objetivo

Prover evidência de viabilidade técnica para um serviço de proteção contra phishing por e-mail dirigido ao usuário individual (pessoa física e microempreendedor), e não ao ambiente corporativo — segmento no qual as soluções atualmente disponíveis no mercado se concentram, com custo e complexidade pouco adequados ao uso doméstico. A abordagem proposta identifica tentativas de phishing por meio de cross-referência entre o conteúdo das mensagens recebidas e uma base documental de templates de comunicação oficial fornecidos por diferentes empresas (padrões de domínio, formatação e canais oficiais).

3. Contexto (resumo)

Hoje, fora o filtro de spam padrão de qualquer provedor de e-mail, toda mensagem que chega à caixa principal é validada manualmente pelo próprio usuário, com base exclusivamente em seu conhecimento e experiência pessoal. O resultado dessa validação varia fortemente com a aptidão técnica do usuário, e uma única falha de julgamento pode ter consequências severas — comprometimento de conta, roubo de dados, propagação de malware ou perda financeira —, agravadas pela sofisticação crescente dos ataques (engenharia social apoiada em IA generativa e deepfakes de voz). O maior custo percebido do processo atual é o tempo gasto pelo próprio usuário verificando manualmente cada mensagem, especialmente relevante para freelancers e microempreendedores cuja comunicação com clientes depende do e-mail.

Dimensão do problema (fonte: Termo de Referência, seção 2): a Kaspersky registrou aproximadamente 553 milhões de tentativas de phishing no Brasil entre julho/2024 e julho/2025; pesquisa citada pelo Banco Central

aponta que 10% dos entrevistados declararam já ter sido vítimas de golpes eletrônicos. Como referência complementar e apenas analógica — não é uma métrica de usuário doméstico —, o relatório KnowBe4 2024 Phishing by Industry Benchmarking (54 milhões de simulações, 11,9 milhões de indivíduos) constatou que, sem treinamento de conscientização em segurança, 34,3% dos usuários corporativos clicariam em links maliciosos ou atenderiam a solicitações fraudulentas.

4. Escopo

4.1 Escopo incluído (núcleo funcional da PoC)

- O sistema opera continuamente em segundo plano (background service / ícone na bandeja do sistema).
- O sistema intercepta, em nível de protocolo (IMAP sobre SSL/TLS, porta 993, via biblioteca MailKit em C#), as mensagens recebidas na caixa de entrada principal do usuário.
- O sistema filtra e seleciona apenas mensagens que contenham ao menos um hyperlink incorporado.
- O sistema valida cada hyperlink encontrado, verificando: (a) se a URL de destino não pertence a um serviço de encurtamento de links conhecido; e (b) se o domínio de destino corresponde a um domínio oficial registrado na base de templates da empresa aparentemente remetente.
- Mensagens em que a validação falhar são marcadas como suspeitas e sinalizadas ao usuário.
- Para cada mensagem suspeita, o sistema gera um relatório detalhando as inconsistências encontradas.
- Nesta PoC, a base de templates é hospedada localmente (localhost) — sem servidor externo dedicado (TR, seção 3.3).

4.2 Escopo excluído (conforme Termo de Referência, seção 3.3)

- Interface gráfica elaborada — interação limitada a notificações nativas do sistema operacional e à bandeja do sistema.
- Servidor externo dedicado além do necessário para hospedar a base de templates.
- Cooperação formal/parceria com provedores de e-mail — o acesso à caixa do usuário ocorre via OAuth2 e IMAP público, mecanismo padrão de qualquer aplicação de terceiros, sem envolver parceria com Google/Microsoft.

4.3 Visão de produto ideal (fora do escopo atual da PoC)

- Sinalização visual das mensagens suspeitas diretamente na caixa de entrada (ex.: marcador semitransparente vermelho) e destaque, dentro da própria mensagem aberta, do trecho exato que gerou a suspeita.
- Base de templates hospedada externamente e atualizável centralmente, sem exigir alteração do binário instalado no cliente.

Ambos os itens são direção futura de produto; não fazem parte dos critérios de aceitação da entrega atual — o primeiro por depender de interface elaborada, o segundo por depender de servidor externo dedicado, ambos explicitamente fora do escopo do TR (seção 3.3).

5. Requisitos Funcionais (RF)

ID	Descrição	Critério de aceitação (TR)
RF-01	O sistema deve operar continuamente em segundo plano, sem exigir interação contínua do usuário.	—
RF-02	O sistema deve autenticar-se à conta de e-mail do usuário por meio de fluxo OAuth2 (Google/Microsoft), sem coletar ou armazenar a senha da conta.	—
RF-03	O sistema não deve realizar nenhuma análise de mensagens enquanto não houver uma autorização OAuth2 válida configurada.	CA-06 (adaptado — ver seção 9)
RF-04	O sistema deve monitorar, via protocolo IMAP com SSL/TLS (porta 993) usando MailKit, as mensagens recebidas na caixa de entrada principal.	—
RF-05	O sistema deve identificar, entre as mensagens recebidas, as que contêm ao menos um hyperlink incorporado.	CA-01
RF-06	O sistema deve ignorar (não analisar) mensagens que não contenham hyperlink.	CA-05
RF-07	Para cada hyperlink das mensagens selecionadas, o sistema deve validar: (a) se a URL de destino não pertence a um serviço de encurtamento de links conhecido; (b) se o domínio de destino corresponde a um domínio oficial registrado na base de templates da empresa identificada (RF-11); (c) se o domínio do endereço de correio eletrônico do remetente também corresponde a um domínio oficial do mesmo template.	—
RF-08	O sistema deve marcar (flag) como suspeita toda mensagem em que a validação de RF-07 falhar.	CA-02
RF-09	O sistema deve sinalizar ao usuário a existência de mensagem(ns) suspeita(s) (ex.: notificação nativa do sistema operacional).	CA-03
RF-10	O sistema deve gerar, para cada mensagem suspeita, um relatório detalhando os elementos/inconsistências identificados.	CA-04
RF-11	O sistema deve identificar, a partir do conteúdo da mensagem, a empresa aparentemente representada, consultando o Registro de Empresas, antes de aplicar as validações de RF-07.	

6. Requisitos Não Funcionais (RNF)

ID	Categoria	Descrição	Critério de aceitação (TR)
RNF-01	Desempenho	O sistema deve concluir a análise de uma mensagem recebida em até 10 segundos após seu recebimento.	CA-07
RNF-02	Segurança	O sistema não deve armazenar nem solicitar a senha da conta de e-mail do usuário; toda autenticação ocorre via OAuth2.	—

ID	Categoria	Descrição	Critério de aceitação (TR)
RNF-03	Segurança	Todo processamento de análise e cross-referência ocorre localmente no dispositivo do usuário (client-side); nenhum conteúdo de e-mail é transmitido a servidores externos.	—
RNF-04	Infraestrutura	Nesta PoC, a base de templates deve ser hospedada localmente (localhost), sem depender de servidor externo dedicado, em conformidade com a restrição orçamentária do TR (seção 6.1).	Seção 3.3/6.1 do TR
RNF-05	Portabilidade	O sistema deve funcionar de forma agnóstica ao provedor de e-mail, desde que este suporte IMAP com SSL/TLS (porta 993) e OAuth2 (ex.: Gmail, Microsoft 365/Outlook).	—
RNF-06	Instalabilidade	O sistema deve poder ser instalado por um usuário sem participação no desenvolvimento, seguindo exclusivamente o manual de instalação e uso.	CA-08
RNF-07	Usabilidade	A interação com o usuário deve se limitar a notificações nativas do sistema operacional e a um ícone na bandeja do sistema, sem interface gráfica elaborada.	—

7. Funcionalidades do Software

Cada funcionalidade abaixo corresponde a um card no quadro Kanban de desenvolvimento; a coluna “Requisito(s) relacionado(s)” indica o que precisa ser satisfeito para o card ser considerado concluído (seção 12).

ID	Funcionalidade	Descrição	Requisito(s) relacionado(s)
F-01	Autorização segura (onboarding)	Concessão de acesso à caixa de entrada via OAuth2, sem uso de senha de aplicativo.	RF-02, RF-03
F-02	Monitoramento contínuo	Observação em segundo plano da caixa de entrada principal via IMAP/SSL.	RF-01, RF-04
F-03	Filtragem por hyperlink	Seleção das mensagens recebidas que contêm hyperlink; descarte das demais.	RF-05, RF-06
F-04	Identificação da empresa	Identificação da empresa aparentemente representada no conteúdo da mensagem, referenciando o Registro de Empresas.	RF-11
F-05	Validação de hyperlink	Checagem de link encurtado e de correspondência do domínio de destino com o domínio oficial da empresa remetente.	RF-07
F-06	Marcação de suspeita	Sinalização interna da mensagem como suspeita quando a validação falha.	RF-08
F-07	Notificação ao usuário	Aviso nativo do sistema operacional sobre mensagem(ns) suspeita(s).	RF-09

ID	Funcionalidade	Descrição	Requisito(s) relacionado(s)
F-08	Relatório de inconsistências	Documento/registro detalhando os elementos que motivaram a suspeita.	RF-10

Os RNFs (seção 6) são transversais — não pertencem a um card específico, mas são critério de aceitação de qualquer card que os toque (ex.: nenhum card pode violar RNF-02, independente da funcionalidade).

8. Matriz de Rastreabilidade (TR × Requisitos)

CA (TR)	Critério de aceitação (Termo de Referência)	Requisito(s) relacionado(s)	Observação
CA-01	O aplicativo deve identificar mensagens que contenham hiperlinks.	RF-05	Conforme
CA-02	O aplicativo deve sinalizar mensagens identificadas como suspeitas.	RF-08	Conforme
CA-03	O aplicativo deve notificar o usuário sobre mensagens suspeitas.	RF-09	Conforme
CA-04	O aplicativo deve apresentar os elementos suspeitos identificados na mensagem.	RF-10	Conforme
CA-05	O aplicativo deve ignorar mensagens sem hiperlinks.	RF-06	Conforme
CA-06	O aplicativo deve impedir a análise quando a senha de aplicativo não estiver configurada.	RF-03, RF-02	Divergente — ver seção 10
CA-07	O aplicativo deve analisar cada mensagem em até 10 segundos após seu recebimento.	RNF-01	Conforme
CA-08	O aplicativo deve ser instalado por terceiro seguindo exclusivamente o manual de instalação e uso.	RNF-06	Conforme

9. Observações e Divergências Identificadas

Durante a entrevista, dois pontos do Termo de Referência v1.0 precisaram de reconciliação com a arquitetura real do projeto (C#, MailKit, IMAP/OAuth2):

- CA-06 pressupõe autenticação por senha de aplicativo. A arquitetura adotada usa OAuth2, um mecanismo diferente. RF-03 reescreve o critério em termos equivalentes (bloqueio de análise sem autorização válida), mas essa é uma mudança de especificação, não apenas de redação.
 - O item “Integração com Provedores de Correio Eletrônico” do escopo excluído (TR, seção 3.3) foi originalmente escrito supondo que qualquer acesso à conta real do usuário estaria fora do alcance da equipe. A equipe esclareceu que o acesso via OAuth2 público (sem parceria/cooperação formal com Google ou Microsoft) não constitui a integração cooperativa que aquele item pretendia excluir, mas ainda assim representa uma dependência de provedor externo que o TR não registrava explicitamente.
 - RF-11 e a extensão (c) de RF-07 formalizam, como requisito, um passo que já estava implícito no mecanismo de validação (a identificação da "empresa aparentemente remetente" citada em RF-07 desde a v1.0) e a comparação do endereço do remetente e a comparação do endereço do remetente, hoje ausente do TR, já que é um detalhe técnico de implementação.
-

10. Definition of Ready (DoR)

Desenvolvimento solo, com apoio de codificação agêntica, organizado em Kanban — cada funcionalidade (seção 7) é um card. Um card está pronto para entrar em “Em andamento” quando:

- O card referencia a funcionalidade (F-XX) e os requisitos e critério(s) de aceitação relacionados (seção 7 e 9).
- Os dados necessários para implementar e testar existem (ex.: amostra local de templates e alguns links de teste — seção 8).
- O card não depende de outro card ainda não concluído.
- O card não esbarra em nada do escopo excluído do TR (seção 3.3 / 4.2).

12. Definition of Done (DoD)

Um card está concluído quando:

- O código está implementado e commitado no repositório.
- A funcionalidade foi testada contra o(s) critério(s) de aceitação relacionado(s) (matriz da seção 9) e passou.
- Nenhum critério de aceitação já conforme foi quebrado por essa mudança (sem regressão).
- Nenhuma credencial, senha ou segredo (client secret, token) ficou hardcoded no código.
- O card foi movido para “Concluído” no quadro Kanban.

13. Controle de Versão do Documento

Versão	Data	Item alterado	Razão e impacto
1.0	24/09/2026	Emissão inicial	Elaborado a partir da entrevista estruturada (Blocos A–H) e do Termo de Referência v1.0.
1.1	25/09/2026	RF-07 estendido, RF-11 adicionado	Formaliza a identificação da empresa por conteúdo e a checagem de domínio do remetente (antes implícitas no algoritmo, sem requisito de origem declarada);